Session-Centric Knowledge Graphs for Explainable Detection and Scoped Mitigation of Distributed Application-Layer DDoS

Natanael Oliveira, Arthur Kobielski, Marcos Luna, Luigi Carro, Jéferson Campos Nobre, and Eder John Scheid
Institute of Informatics, Universidade Federal do Rio Grande do Sul (UFRGS), Porto Alegre, Brazil
{natanael.oliveira, arthur.kobielski, marcos.luna, carro, jcnobre, ejscheid}@inf.ufrgs.br

***Abstract*—Distributed Slow HTTP DoS campaigns keep every source below any reasonable per-session threshold, so the attack signal lives in the structure *between* sessions. Detectors discard that structure by reducing the session to a numeric vector, and recent knowledge-graph detectors reason at the network-node level and stop at a textual report. We model the HTTP session as a first-class ontological entity in OWL and replace the flat `relatedTo` link with six typed sub-properties weighted by the attacker's cost of breaking each signal. A SPARQL/SWRL rule fires on their weighted mass, and its derivation *is* the verdict, exported as a JSON-LD and STIX 2.1 evidence chain whose discriminator scopes the mitigation. Against stealthy distributed campaigns, per-session detection stays at chance across four classifier families given the full flow-feature set, while cross-session representation reaches ROC AUC 0.98 against 0.50; on public datasets, whose attacks carry an obvious flow signature, a strong per-session baseline already suffices. Scoping mitigation by the property most of the cluster shares is harmful, selecting a *legitimate* fingerprint once the botnet spans several TLS stacks and blocking 0% of the attack against 39% of legitimate traffic; choosing the discriminator by enrichment blocks 85–90% with no collateral observed. Measured as a detector, the symbolic path needs no training and no learned threshold, yet recovers two to five times more of a fragmented campaign than the learned model at the same zero-false-positive operating point.**

***Index Terms*—security management, knowledge graph, application-layer DDoS, semantic models, automated reasoning, explainability, mitigation policy**

I. Introduction

Application-layer DDoS has changed in kind, not only in scale. In August 2023, HTTP/2 Rapid Reset (CVE-2023-44487) pushed mitigated peaks to 398 million requests per second from a botnet of roughly twenty thousand machines [1], [2], and Cloudflare blocked more than 6 500 hyper-volumetric attacks in Q2 2025 alone, with HTTP DDoS growing 129% year over year [3]. Volumetric defenses answer the high-rate end of this spectrum; the low-rate end is where detection is harder. The family of *distributed Slow HTTP DoS* attacks covers Slowloris and its descendants, plus rate-based variants that still hold connections open, such as HULK and GoldenEye [4]. These exhaust a server from many coordinated origins, each contributing so little that no per-source threshold is crossed. Modern HTTP/2 attacks share that multi-origin exhaustion property, but they operate through distinct mechanisms, notably stream cancellation and header continuation abuse. Those call for sub-relations outside the scope we evaluate here, and we treat them as the immediate extension target (Section VII) rather than as a claim of this paper.

Examined individually, each request is statistically indistinguishable from a legitimate one; the discriminative signal resides in the structure *between* sessions, in connection duration, route entropy, client fingerprint consistency and the convergence of many origins on one endpoint under one client signature [5]. The problem is therefore one of network and service management as much as of detection: an operator requires not a label but a decision, namely *which* clients to act on, on *what* evidence, and with a filter narrow enough not to disconnect the legitimate users of the service under attack.

Existing work addresses the detection half and largely leaves the operational half open. The meta-analysis of Odusami et al. [6] over seventy-five studies finds that 47% of application-layer DDoS methods derive features from sessions, such as request rate per user, mean duration and operations per identity. In our inspection of those studies, the session is consistently flattened into a numeric vector before it reaches the classifier. The detector sees statistics, not sessions, and therefore cannot reason about reused identities, about fingerprints converging on an endpoint, or about patterns that only exist between two individually normal sessions.

Contemporary work attacks the opacity of these detectors with graphs. KLAGE, by Belcastro et al. [7], builds knowledge graphs from network logs, classifies nodes with Graph-BERT, and produces natural-language reports via LIME and large language models, reaching $F_1 = 84.1\%$ on IoT benchmarks that include DDoS Slowloris. It is solid evidence that knowledge graphs are a viable runtime detection substrate. Three gaps, however, remain. Its reasoning unit is the *network node* (port, IP, flow) rather than the application session. Coordination is captured implicitly, in learned embeddings, not in named symbolic relations. And the pipeline ends at a report, without a mitigation policy whose scope is derived from the graph itself. Those three gaps define the space this paper occupies.

Contributions. This paper contributes (i) an OWL ontology in which the HTTP session is a first-class entity, related to other sessions by *six typed sub-properties* weighted by the attacker's cost of breaking each signal, so that network proximity, trivially broken by modern botnets, enters as auxiliary evidence and never as a prerequisite; (ii) a decision procedure in which a SPARQL/SWRL rule fires on the weighted coordination mass $\Omega(S)$ of a candidate cluster, so that what is reported is the derivation that satisfied the rule rather than a classifier score explained after the fact; (iii) a mitigation scope derived from that same graph and carried with a JSON-LD and STIX 2.1 evidence chain, together with the finding that the natural derivation, the property most of the cluster shares, is harmful under realistic conditions, and an enrichment criterion over a profile of normal traffic that replaces it; and (iv) an evaluation parameterized by the degree of distribution against a strong per-session baseline, reporting the fraction of legitimate traffic the resulting mitigation blocks, a metric self-reported by commercial bot-management products but not, to our knowledge, used systematically in the academic Layer-7 literature.

Section III presents the framework, Sections IV and V the methodology and results.

II. Related Work

Table I positions the closest work on the axes this paper turns on: the unit of reasoning, the representation of relations between sessions, the form of the explanation, and whether a mitigation scope and its collateral cost follow from that same representation.

A. Knowledge Graphs for Security and Management

The first wave of security knowledge graphs was *static*: entities extracted from CVEs, reports and blogs, normalized and linked into a queryable base [13], [14]. The survey of Liu et al. [15] states the resulting gap: "it is still unclear how to implement the knowledge graph to face real industrial difficulties in cyber attack and defense situations". Graphs built from threat intelligence text do not capture runtime traffic structure.

More recent work populates graphs from traffic itself. KLAGE [7] is the closest exemplar and the one we compare against. Graph representations are also gaining ground in management tasks adjacent to ours: Sadlek et al. [10] identify device dependencies through link prediction over network graphs, and Wang and Stadler [11] learn attack action sequences from testbed measurements. Both operate on network-level entities, and neither derives a mitigation scope.

B. Layer-7 HTTP DDoS Detection

Detection work falls historically into two strands, over a body of surveys that consolidate the domain [4], [16]. Statistical profiling builds baselines from aggregated flow or session statistics: Fernandes et al. [8] apply PCA to flow statistics, and Bharathi and Sukanesh [9] to a per-session behavioral matrix. The latter is among the first formulations to put the session at the center, though still as a feature vector. Supervised learning over session features is the second family, with Kemp et al. [5] as the most recent representative; its authors note that the method was not validated in real time and that the output is binary, without ontological explanation.

C. Session Modeling in Anomaly Detection

The meta-analysis of Odusami et al. [6] gives the clearest quantitative evidence of how the session is handled: in 47% of the cataloged methods, session-derived features feed the classifier; across the seventy-five studies we found none in which the session is kept as an object with identity, target, behavior and typed relations. The reduction is uniform, and it places cross-session reasoning beyond the detector's reach.

Industrial bot-management platforms do exploit cross-session structure, grouping apparently independent sessions by TLS stack similarity through JA4-family fingerprints [12]. They are proprietary, however, with no public ontology, no reproducible academic benchmark, and no formalized collateral-damage metric. Formalizing that practice auditably, and deriving mitigation scope from an explicit ontological rule, remains open.

III. Session-Centric Knowledge Graph

Fig. 1 summarizes the framework. Four stages run over live traffic: HTTP events are ingested; lifted into ontology instances with sessions as persistent graph nodes; evaluated by semantic rules; and turned into a verdict carrying its evidence chain and derived mitigation scope.

A. Background

A knowledge graph states facts as RDF triples $\langle$subject, predicate, object$\rangle$, and an OWL 2 ontology declares the classes and properties they may use. We work in the OWL 2 RL profile [18], whose polynomial forward-chaining entailment makes bounded materialization tractable for runtime reasoning where OWL 2 DL is not; it runs once per operational window rather than on the per-request path. SWRL adds Horn rules, which assert a triple when a conjunction of premises holds; SPARQL queries the result and, unlike SWRL, aggregates over solution sets. Client identity comes from JA4 [12], a hash of

TABLE I
Comparison of Related Work.

Work	Year	Target	Reasoning unit	Cross-session relation	Verdict explanation	Mitigation scope	Collateral
Fernandes et al. [8]	2015	flow anomalies	flow statistics	—	—	—	—
Bharathi and Sukanesh [9]	2012	L7 DDoS	session as vector	—	—	—	—
Kemp et al. [5]	2023	L7 DoS	session as vector	—	—	—	—
Sadlek et al. [10]	2024	device dependencies	network device	implicit (learned)	—	—	—
Wang and Stadler [11]	2024	IT intrusion	host	implicit (learned)	—	—	—
KLAGE [7]	2026	network threats	network node	implicit (learned)	post-hoc (LIME/LLM)	—	—
Industrial bot management [12]	—	bot traffic	session	proprietary	—	undisclosed	self-reported
This work	—	distributed L7 DDoS	application session	explicit (typed, weighted)	derivation	derived	reported

A dash marks a dimension outside the stated scope of a work, not a shortcoming; *target* states each work's own objective.

the TLS *ClientHello* that fingerprints a client's TLS stack, not its address, and so survives IP rotation.

B. Ontology

The central class is `ApplicationSession`, related by `hasIdentity` to a composite `Identity` (cookie, JWT token, username, TLS fingerprint), by `targets` to an `Endpoint` (`AuthEndpoint`, `APIEndpoint`, `StaticAsset`), by `exhibitsBehavior` to a behavioral profile, and by `mitigatedBy` to a policy (`RateLimit`, `Challenge`, `Block`) carrying a `scope` attribute. The abstract class `ApplicationLayerAttack` specializes into `SlowHTTPDoSFamily`, itself split into `ConnectionExhaustionAttack` (Slowloris, slow body, slow read) and `CoordinatedHTTPFlood` (HULK, GoldenEye). The ontology is aligned with STIX 2.1 [17] and MITRE ATT&CK, and also declares `CredentialStuffing` and `CoordinatedAPIAbuse`, which reuse the same machinery but are outside the experimental scope of this paper.

C. Threat Model

The defender operates the attacked application and observes, per request, the TLS *ClientHello* (hence a JA4 fingerprint), source address and prefix/ASN, target endpoint, arrival time, and whatever identity material the application exposes. The defender sees neither the botnet's control channel nor any ground truth about which sources are coordinated, but can profile the service's own traffic outside attack episodes. The attacker controls K origins, places them in the network, and may shape each session to be statistically indistinguishable from a legitimate one, which is the stealth assumption of our evaluation. The attacker may also break individual coordination signals, forging JA4 with browser-impersonating libraries, jittering timing, rotating identities or randomizing payloads, each at an operational cost that the weighting of Section III-D encodes; Sections V-D and VI report what happens when the strongest signal is taken away.

D. The Weighted `relatedTo` Family

Cross-session relatedness is not one relation but a structured family, declared via `rdfs:subPropertyOf` under a transitive `relatedTo` and annotated with a `coordinationWeight` $w_i \in [0, 1]$, listed in Fig. 1. Each is instantiated independently from its own observed evidence, so two sessions may be linked by one, several or all six.

The ordering is an evasion-cost argument. Changing the TLS stack forces the attacker to rewrite infrastructure, which is why JA4 survived the extension randomization Chrome introduced in 2023 whereas classic JA3 did not [12]. Identity reuse is equally expensive to break, because pulverizing credentials attacks the economics of the campaign itself. Temporal coherence emerges from botnet operation rather than from the client stack, and random jitter can partially break it. Payload and endpoint signals are middling: randomizing them is cheap, but doing so costs campaign coherence. Network proximity is the weakest link by construction: Mirai derivatives, cloud fleets and residential-proxy networks spread across ASNs and prefixes, and carrier-grade NAT makes a shared /24 a poor discriminator. The calibration in Appendix B corroborates that ordering, not the absolute values.

E. Runtime Graph Construction

Sessions and relations live inside a sliding operational window ($W = 5$ min by default) and are purged incrementally, following an RDF stream-processing discipline. Materialization runs over Apache Jena Fuseki with TDB2 storage. Fig. 2 lays out the two layers and the rates they run at; Appendix A gives the construction algorithm and the per-pair decision procedure of each `relatedBy` sub-relation. Admitting a new session into a window holding $|S_W|$ active sessions costs $O(|S_W| \cdot c)$, with c amortized $O(1)$ for every sub-relation except the temporal one, which is dominated by FastDTW under a Sakoe–Chiba band. Section V-E measures both this admission path and the symbolic layer against window occupancy.

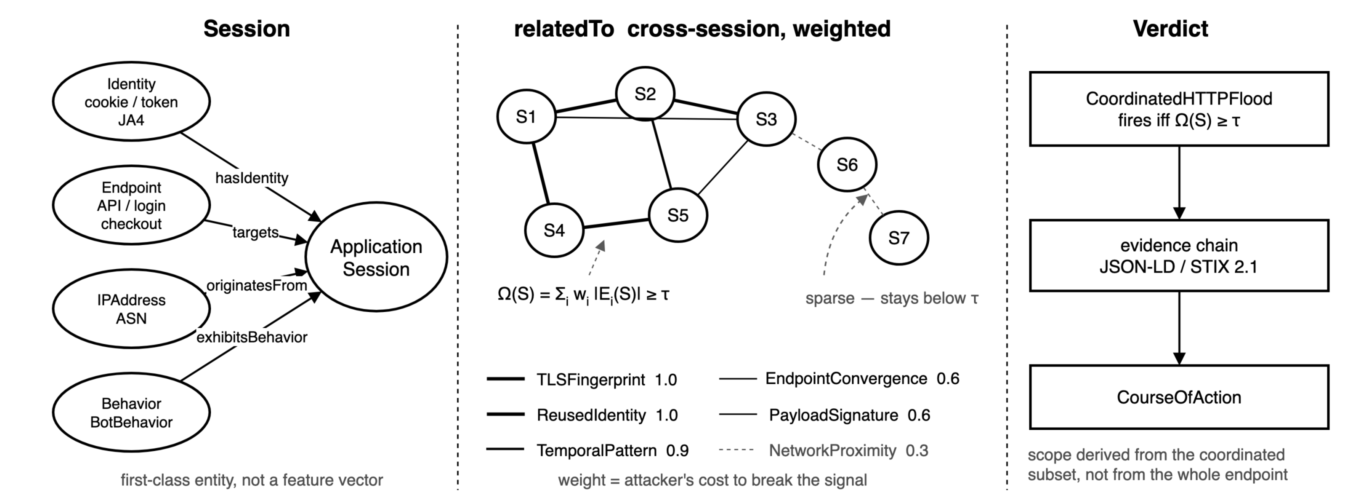

Fig. 1. Session-centric ontology and detection rule.

F. Detection Rule

Let V_{sess} be the sessions active in W. For a subset $S \subseteq V_{\text{sess}}$ and a candidate endpoint e, define the *coordination mass*

$$\Omega(S) \;=\; \sum_{i \in \mathcal{R}_{\text{rel}}} w_i \, \big|E_i(S)\big|, \tag{1}$$

with $E_i(S) = \{\{s_a, s_b\} \subseteq S : (s_a, \texttt{relatedBy}_i, s_b) \in E\}$ the set of session pairs linked by sub-relation i. Sub-relations are symmetric, so each unordered pair counts once. The rule `CoordinatedHTTPFlood` is satisfied when there exists S with (i) $|S| \geq k_{\min}$; (ii) $\forall s \in S : (s, \texttt{targets}, e) \in E$; (iii) $\Omega(S) \geq \tau_{\text{cluster}}$; (iv) aggregate rate on e above τ_{rate}; and (v) a coherent `BotBehavior` profile.

Condition (iii) is the contribution. $\Omega(S)$ can clear the threshold with `relatedByNetworkProximity` at zero, which is the distributed-botnet case, provided some combination of high-weight signals is observed. Conversely, a set held together *only* by network proximity, such as legitimate mobile users behind one CGN /24, needs over three times as many linked pairs to reach the same Ω as a TLS-linked set, and τ_{cluster} is calibrated on legitimate clusters, so ordinary CGN aggregation stays below it. This is explicit protection against a well-known false-positive mode.

G. Symbolic Formulation

Reasoning is symbolic in two stages, and the split is deliberate. Pair-wise materialization of the `relatedBy` family is expressed as SWRL rules over predicates the evidence extractors produce: the equality-based relations are pure Horn, while numeric ones such as DTW distance and payload cosine similarity are evaluated beforehand and enter the rule as a built-in comparison against their threshold. Aggregation is not Horn at all, because SWRL cannot sum, so $\Omega(S)$ is computed by a SPARQL query whose weights are read from the `coordinationWeight` annotations in the ontology rather than hard-coded. Listing 1 in Appendix A shows one rule of each kind.

H. Evidence Chain and Derived Mitigation Scope

When the rule fires, the engine emits the satisfied rule, the ontology instances involved, the decomposition of $\Omega(S)$ per sub-relation, and the derived mitigation scope. We export this as JSON-LD over the ontology vocabulary and as STIX 2.1, an *indicator* plus a *course-of-action* linked by *mitigates*, for SIEM and SOAR ingestion.

How the scope is chosen decides whether the verdict is useful or harmful, and the frequency-based choice fails. The modal fingerprint of the cluster selects whatever is common, and on a service under attack what is common is the legitimate population: against a botnet spread over several TLS stacks, each attacker stack is smaller than the head of the benign distribution, so the modal value is a *legitimate* fingerprint and the resulting filter blocks users and no attackers (Section V-D).

We therefore select the discriminator by **enrichment** rather than by frequency. Let $c(f)$ be the prevalence of fingerprint f inside the fired cluster and $b(f)$ its prevalence in a background profile of normal traffic maintained by the operator outside attack episodes. The scope admits every f with $c(f)/b(f) \geq \rho$ and $c(f) \geq \sigma$, yielding a *set* of fingerprints rather than one, which covers a fragmented botnet. The support floor σ must sit below the share of the smallest stack worth acting on, that is, below $1/M$ for a botnet of M stacks. Lowering it costs nothing, because the enrichment test, not the floor, keeps legitimate traffic out. We use $\rho = 3$ and $\sigma = 0.002$.

The background must come from outside the attack episode: the campaign spans the whole window, so using the window itself makes cluster and background prevalences coincide and every candidate score an enrichment of one. No labels are involved, the profile being what a defender observes in normal operation. A useful property follows: an adversary hiding inside a popular benign fingerprint is by definition not enriched, so the scope is refused and the framework reports that no discriminator exists instead of emitting a filter that only harms users.

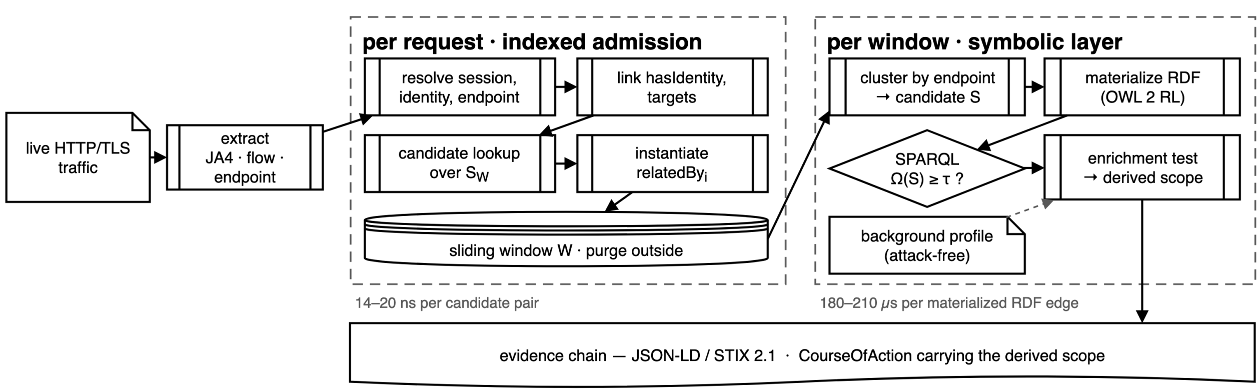

Fig. 2. Runtime pipeline, per request and per window.

IV. Evaluation Methodology

A. Scenarios and Datasets

The central hypothesis has two parts: cross-session representation gains over per-session detection as the *degree of distribution* K of the campaign grows, and the symbolic path turns that structure into an auditable, low-collateral decision. The evaluation is therefore parameterized by K rather than by attack name. **Scenario A (concentrated, $K = 1$)** is the classic single-source high-volume attack: no cross-session edge is needed for detection and conventional volumetric detectors are expected to suffice; it is degenerate for per-session AUC and we discuss it separately. **Scenario B (moderately distributed, $10 \leq K \leq 100$)** models small botnets or proxy-limited operations, each origin staying inside its own rate limit; here network proximity is only partial and high-weight signals must carry detection. **Scenario C (highly distributed, $K \geq 1000$)** disperses the campaign across hundreds of ASNs and prefixes, so per-session signal is negligible and `relatedByNetworkProximity` is nearly empty. This is the regime in which the contribution has to hold if it is to be operationally meaningful. We report B ($K = 50$) and C ($K = 1000$).

Primary evaluation: calibrated synthetic traffic. A generator produces distributed Slow HTTP DoS campaigns, the family of Section III-B: sustained low-rate sessions against one endpoint, with perfectly known coordination ground truth, parameterized by K, by the fraction of origins sharing TLS signature and identity, by IP/ASN dispersion and by the time window.

Two parameters of that generator decide whether the scenario resembles production, and both are calibrated rather than assumed. Benign fingerprint popularity is shaped as a Zipf curve of exponent α: real populations are concentrated, since an up-to-date browser on a given platform emits essentially one JA4 [12], whereas drawing benign fingerprints uniformly would make every legitimate client nearly unique. We calibrated that curve against 6.33M TLS requests logged at a production edge point of presence of Azion Technologies[1]: 495 distinct fingerprints, the most common accounting for 38.4% of requests and the top ten for 93.8%. The measured curve is bracketed by $\alpha = 1.5$ and $\alpha = 2.0$; we take $\alpha = 1.5$ as canonical and sweep the range. Botnet composition matters as much: real botnets span device classes such as routers, IP cameras and DVRs [20], and therefore TLS stacks, so we distribute the campaign uniformly over M stacks, the conservative choice for a given M, with $M = 25$ canonical and swept because no published measurement fixes it. An *adversarial* mode additionally lets the botnet adopt the most common benign fingerprints instead of its own, which browser-impersonation tooling makes operationally feasible. Appendix B reports the measurement, its caveats and the comparison against laboratory datasets.

[1]Measured 22 August 2026 from an access log the platform already collects; the extract holds only client-software fingerprints and their frequencies, with no address, host, URI, header or locale.

Legitimate distributions are calibrated against the $\sim$322k benign sessions of CICIDS2017 and verified by Kolmogorov–Smirnov tests: $D = 0.003$ for duration and $D = 0.002$ for request count, both with $p > 0.8$, so the observed gain cannot come from artificially easy benign traffic. A *stealth* mode draws attacker sessions from the same per-session distributions as benign traffic, so the campaign reveals itself only through cross-session structure.

Real data. CICIDS2017 [19] (Wednesday capture: Slowloris, Slowhttptest, HULK, GoldenEye) and CIC-IoT2023 [21], the latter being the dataset on which KLAGE reports $F_1 = 84.1\%$ for `DDoS Slowloris`, run through the same extraction pipeline (PCAP $\rightarrow$ JA4 + flows $\rightarrow$ sessions $\rightarrow$ graph). Both are laboratory testbed captures, not production traffic, a caveat we return to in Section VI.

B. Baselines, Configurations and Metrics

Every combination is run $n = 30$ times with distinct seeds, giving bootstrap confidence intervals and paired tests. All configurations consume the same underlying traffic attributes, so the ablation separates *representation*, not data availability. τ_{cluster} is fixed per scenario at the 99th percentile of Ω over legitimate clusters.

The per-session baseline is deliberately **strong**: a Random Forest over all eight to nine available flow attributes (request count and duration, byte and packet sums in both directions, mean and standard deviation of inter-request time). To keep the negative result from depending on one hypothesis class, we repeat it with histogram gradient boosting, a multilayer perceptron and logistic regression over the same features. We also reimplement three academic baselines: PCA profiling [8], k-means over a behavioral matrix [9], and supervised RF/SVM over session features [5]. We compare against published KLAGE numbers on the same dataset and attack. The four ablation configurations are: **(a)** ML baseline without ontology; **(b)** ontology with *no* `relatedBy` sub-relation, sessions as isolated nodes; **(c)** ontology with *only* `relatedByNetworkProximity`, emulating a naive ASN/prefix detector; and **(d)** the full cross-session feature representation over the three sub-relations observable in the evaluated traffic. Thus (d)$-$(a) is the total contribution, (d)$-$(b) the gain of representing cross-session structure at all, and (d)$-$(c) the gain of high-weight signals over network proximity.

Configuration (d) consumes the cross-session evidence as *features*, namely the share of a cluster carrying the same JA4 or the same /24 plus the cluster size, rather than by querying the RDF graph. It is a feature-level proxy for the representation the `relatedBy` family encodes, chosen so that every configuration differs only in representation, not in the underlying data or the classifier.

Beyond standard classification metrics we report **collateral damage**: the fraction of legitimate traffic falling inside the scope derived from the verdict. Evidence chains are assessed for *completeness* (do they enumerate every correlated session

TABLE II

PER-SESSION ROC AUC [95% CI], REALISTIC SYNTHETIC SCENARIO ($\alpha = 1.5$, $M = 25$), $n = 30$ SEEDS, STRONG PER-SESSION BASELINE, LEGITIMATE USERS ON THE ATTACKED SERVICE.

Configuration	$K = 50$	$K = 1000$
(a) per-session ML (strong)	0.498 [.47–.53]	0.503 [.50–.51]
(b) ontology, no `relatedBy`	0.500 [.47–.53]	0.502 [.49–.51]
(c) `NetworkProximity` only	0.499 [.46–.53]	0.659 [.65–.67]
(d) cross-session repr.	**0.927 [.92–.93]**	**0.982 [.98–.98]**
(a) and (d) across classifier families (point estimates)		
hist. gradient boosting	0.502 / 0.921	0.501 / 0.990
multilayer perceptron	0.471 / 0.235†	0.500 / 0.803
logistic regression	0.488 / 0.873	0.495 / 0.799
Fernandes et al. [8]	0.518	0.509
Bharathi and Sukanesh [9]	0.520	0.509
Kemp et al. [5]	0.499	0.503

Configuration (d) reaches the cross-session evidence through features rather than SPARQL, so this table measures the representation; the symbolic path is evaluated separately in Table III. † below chance: the perceptron inverts, having learned that a widely shared fingerprint indicates benign traffic. See text.

TABLE III

THE SPARQL/ENRICHMENT PATH AS A DETECTOR, AGAINST THE LEARNED MODEL FORCED ONTO THE SAME OPERATING POINT, EXCEPT IN THE ADVERSARIAL ROW (SEE TEXT). $K = 1000$, $n = 15$ SEEDS.

	symbolic rule			learned model (d)	
Scenario	recall	FPR	F_1	AUC	rec. @ FPR= 0
monolithic (M=1)	84.0%	0.00%	0.885	0.997	91.7%
M=5	90.0%	0.00%	0.948	0.996	88.6%
M=25	90.3%	0.00%	**0.949**	0.979	**36.4%**
M=100	85.0%	0.00%	0.919	0.961	**17.6%**
M=25, adversarial	30.4%	3.78%	0.452	0.862	7.8%

and activated sub-relation?) and *actionability* (is the derived scope coherent with the cluster discriminator?).

V. RESULTS

A. Ablation Under Stealthy Distributed Campaigns

Table II reports per-session ROC AUC over stealthy distributed campaigns in which legitimate users access the *same* endpoint on the same port as the attack, so neither flow volume nor destination port separates the two classes. The pattern survives a strong baseline: per-session detection (a) with the full flow-feature set, the three academic baselines, and configuration (b), which adds per-session ontological attributes but no cross-session relation, all sit at chance (AUC ≈ 0.50), because each attacker session is by construction drawn from the benign distributions. The cross-session representation (d) reaches 0.93–0.98. Configuration (c), restricted to network proximity, is weak (0.50–0.66) because the botnet is dispersed.

Across the four hypothesis classes, configuration (a) stays at chance for every family, at 0.471–0.502, so the collapse is a property of the representation, not of the learner; the three reimplemented academic baselines, which consume the same feature set, land in the same place.

Configuration (d) is where model choice starts to matter, and the realistic scenario exposes why. Fragmenting the botnet over 25 stacks makes the cross-session evidence *non-monotonic* in the label: an attacker shares a fingerprint with a few dozen peers, while a legitimate client in the head of the benign distribution shares it with hundreds. Tree ensembles carve out the intermediate band and reach 0.98–0.99 at $K = 1000$ and 0.92–0.93 at $K = 50$; logistic regression, restricted to a monotone response, drops to 0.80 and 0.87; and the perceptron inverts outright at $K = 50$ (AUC $= 0.235$), having learned that a widely shared fingerprint indicates benign traffic. The paired contrasts on the reference learner remain significant ($p_{\mathrm{Bonf}} = 7.5 \times 10^{-9}$; Cohen's $d = +22.4$ for (d)$-$(a) and $+13.5$ for (d)$-$(c) at $K = 1000$).

The non-monotonicity argues for the symbolic path rather than against the approach: a learned model must infer the benign baseline from its training sample and encode it in a boundary, whereas the rule of Section III-H compares against an explicit profile. Enrichment, by contrast, behaves uniformly across the fragmentation range where the learners diverge.

That (b) also sits at chance shows that per-session ontological attributes are not enough; the *explicit relation between* sessions carries detection.

The mass of $\Omega(S)$ that fires the rule is dominated by `relatedByTLSFingerprint` ($w = 1.0$) and endpoint convergence; `relatedByNetworkProximity` does not activate in dispersed campaigns. We also assessed evidence-chain quality over seven real attack clusters: all seven enumerate the satisfied rule, the activated sub-relations with weights, the $\Omega(S)$ score and the derived scope, and all yield a directly applicable filter (Listing 2, Appendix D). A human-analyst study remains future work.

B. The Rule Itself as a Detector

Every number so far came from a classifier over cross-session features, which says nothing about the symbolic layer. We therefore evaluate the rule directly: the sessions matching the scope derived in Section III-H *are* the flagged set, with no model training and no learned score threshold, and the decision arrives with its derivation. Since AUC is a ranking measure and the rule emits a hard decision, we also force the classifier onto the rule's own operating point (Table III).

Against a monolithic or lightly fragmented botnet the learned model is competitive at zero false positives (91.7% and 88.6% recall against 84.0% and 90.0%): there is no symbolic advantage in the easy regime. From 25 stacks on the ordering reverses: 90.3% against 36.4%, and 85.0% against 17.6% at one hundred stacks, and the rule holds that lead even against a model allowed to spend false positives: at 1% FPR the model reaches only 66.8% and 44.5%. The adversarial row is *not* a like-for-like comparison and we make no claim from it: there the rule itself incurs a 3.78% false-positive rate, and the model reaches 23.4% once allowed 1%, so the ordering at a matched operating point is unresolved.

AUC alone does not capture this operating-point behavior. The classifier still scores 0.979 and 0.961 where it recovers a third and a sixth of the attack: its ranking is good, but its scores overlap benign traffic in the tail, so no threshold yields automatic action without collateral. The rule produces no score to threshold; it produces a set defined by an enrichment test against an explicit background, so its zero false-positive rate

TABLE IV
DDoS Slowloris on CIC-IoT2023 (*real data*, 143 distinct /24 prefixes).

Method	F_1	Prec.	Rec.	AUC
KLAGE, node level [7]	0.841	—	—	—
(a) per-session ML, 3 feat.	0.179	0.691	0.103	0.551
(a′) per-session ML, 8 feat.	0.900	0.901	0.899	0.987
(d) cross-session (ours)	**0.911**	0.908	0.915	0.982

in these scenarios follows from that criterion rather than from a tuned threshold, which is not an unconditional guarantee.

C. Real Traffic and Comparison with KLAGE

Table IV differs from Table II. A *lean* per-session baseline (three attributes) collapses to $F_1 = 0.179$, but a *strong* one (eight flow attributes) reaches $F_1 = 0.900$, because real CIC-IoT2023 Slowloris, unlike our stealthy synthetic campaigns, leaves a per-session flow signature. The cross-session framework reaches $F_1 = 0.911$, ahead by only $+0.011$.

On this real attack, cross-session coordination is not necessary: a competent per-session classifier separates it, because the attack was never calibrated to mimic benign flow. The comparison with KLAGE is favorable but *uncontrolled*: our 0.911 beats the published 0.841, yet so does our own strong baseline at 0.900, so the margin cannot be attributed specifically to the cross-session representation. A controlled rerun is not currently possible: the released code starts from a pre-built graph whose construction from the raw dataset is unpublished and ships no weights, so any rerun would rest on our own reconstruction of it. The necessity of cross-session evidence appears only in the stealthy distributed regime, which public DDoS datasets, restricted to attacks with obvious flow signatures, do not contain (Fig. 4, Appendix C). Unconditionally over the node-level state of the art, the approach adds an auditable symbolic verdict and a measurable collateral-damage figure.

D. Collateral Damage on Legitimate Traffic

Mitigation is only meaningful as a pair: what the derived scope blocks, and what it costs. We report both over $n = 15$ campaigns per configuration, comparing the frequency rule against the enrichment rule of Section III-H (Fig. 3).

For a monolithic botnet the two agree: 84.0% of attacker sessions blocked with no collateral observed, against 100% for a global endpoint rate limit, which by definition disconnects every legitimate user of the attacked service. That is the regime in which the frequency rule was validated, and it is not representative. From five stacks on, the modal fingerprint of the cluster becomes a *legitimate* one and the rule inverts: 0.0% of the attack blocked and 39.0% of legitimate traffic hit, a net loss that imposes the cost of mitigation without its benefit. A more concentrated benign population ($\alpha = 2.0$) raises that collateral to 61.1%.

Enrichment removes the failure, blocking 90.0%, 90.3% and 85.0% of the attack at $M = 5$, 25 and 100 stacks, in every case with **no collateral observed** across the $n = 15$

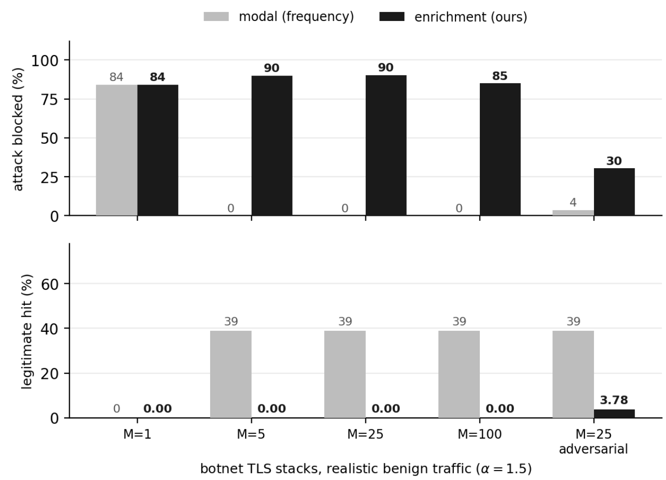

Fig. 3. Scope derivation: frequency versus enrichment ($\alpha = 1.5$, $n = 15$).

campaigns, and reproducing the frequency rule where the latter worked. The surviving 10–15% is the tail of attackers with one-off fingerprints: scoped mitigation trades completeness for precision.

Two conditions bound the result. The first is adversarial: when the botnet adopts common benign fingerprints, little is enriched and the rule blocks 30.4% of the attack at 3.78% collateral, against 3.6% and 39.0% for the frequency rule. The selectivity advantage is largely lost, but it is lost *safely*: with a stricter ρ the scope declines to name a fingerprint and degenerates to the global control, the correct report when no discriminator exists. The second is the background profile. Moderate drift is tolerable ($\alpha = 2.0$ profile against an $\alpha = 1.5$ episode: 90.3% coverage, 0.45% collateral); a flat or missing profile is not, since every fingerprint then looks rare, the benign head scores as enriched, and collateral jumps to 81.2%. Coverage is unaffected throughout, since profile quality governs precision, not recall, so maintaining it is a deployment requirement and not an optimization. It also implies a fail-safe. Where the profile fails a freshness or drift check, scoped mitigation should be suppressed and the verdict emitted as evidence only, the same abstention the enrichment test already performs when nothing is enriched.

E. Cost and the Choice of W

Appendix D measures both layers of the pipeline against window occupancy. Two results are operationally relevant: admission costs a constant 14–20 ns per candidate pair, sustaining some $84\,000$ session admissions per second on one core at $|S_W| = 1\,000$; and detection is flat over a $30\times$ range of W while cluster occupancy, and with it the quadratic pair term that $\Omega(S)$ implies, grows $6.6\times$. These results favor choosing W as small as the traffic permits.

F. Statistical Significance

Paired Wilcoxon tests over the $n = 30$ runs, with Bonferroni correction and Cohen's d, make both contrasts significant in the distributed regime ($K = 1000$) at $p_{\mathrm{Bonf}} = 7.5 \times 10^{-9}$:

(d)$-$**(c)** with $d = 13.5$ and **(d)**$-$**(a)** with $d = 22.4$. The matched-pairs rank-biserial correlation is $+1.00$ for both, (d) winning all 30 paired runs. Effect sizes of this magnitude reflect the near-perfect separation of controlled synthetic traffic and should not be read as an expectation of field performance.

VI. Discussion and Limitations

Five principal limitations bound our claims; Appendix C lists additional ones.

The gain is regime-specific. Against single-source high-volume attacks, per-IP or per-session thresholds perform comparably, and on the conventional real attacks available in public datasets a strong per-session classifier already reaches AUC ≥ 0.98, leaving cross-session representation only a marginal gain. The advantage holds only when the campaign is distributed *and* stealthy. This work does not replace volumetric defenses; it complements them.

The synthetic evaluation demonstrates a mechanism, not field performance. In the synthetic setting the coordination signals present in the campaign are exactly those measured by configuration (d), and attacker sessions draw their per-session attributes from real benign distributions. The per-session non-separability in Table II is therefore not an artifact of a weakened baseline. The mimicry is imposed by construction, so the result shows the mechanism under an assumption of perfect per-session indistinguishability, rather than proving performance on a real capture of that regime.

Detection and scoping both depend on an observable high-weight discriminator. A robustness sweep ($n = 10$) makes the dependency explicit: as the fraction of origins sharing the TLS fingerprint falls, AUC(d) decreases monotonically from 1.00 to ≈ 0.74 under full randomization, and that residual is an artifact of a finite benign JA4 pool that internet-scale diversity should drive to chance. Endpoint convergence does *not* compensate, because legitimate users converge on the endpoint too. Adversaries can forge JA4, jitter timing and rotate identities; the weighted family tolerates partial breakage, since surviving high-weight signals carry the cluster, but breaking three or more at once degrades it toward chance. Encrypted Client Hello [22] could likewise make JA4 unobservable.

Operational placement. The framework closes a management loop rather than emitting labels: detection, evidence and scope come from one pass over the same graph, so what reaches the operator or a SOAR playbook is a STIX *course-of-action* already parameterized by the discriminator that justified the verdict. The sliding window bounds that cost (Section V-E).

Parallelism and partitioning. The rule dictates the natural shard key. Condition (ii) requires every session of S to target the same endpoint e, so partitioning the active window by endpoint evaluates `CoordinatedHTTPFlood` *exactly*, with no cross-shard traffic, and because the window bounds $|S_W|$, per-shard state does not grow with cumulative traffic volume. The cost is not zero: sharding by endpoint hides a campaign that spreads one JA4 across many endpoints, since no shard accumulates enough coordinated pairs to clear τ_{cluster}, whereas sharding by JA4 preserves those campaigns and breaks the endpoint condition. No single key preserves all six sub-relations, and that is a property of $\Omega(S)$ rather than of any implementation. Appendix D sketches the two-tier design this suggests and states what it leaves unquantified.

Scope of the ablation. Configuration (d) reaches the graph's evidence through features rather than through SPARQL: a linear model over the same three cross-session features still attains 0.799 against 0.495 for the per-session set, so the AUC gain in Table II is attributable to representing cross-session structure, not to expressing it in OWL. The formalism is not intended to raise AUC but to provide a typed, inspectable vocabulary in which verdict, evidence and scope form a single derivation, exportable to STIX without a translation step. It is evidenced separately by Table III, and only in part: it does not beat the learned model against a monolithic botnet, and its advantage appears once fragmentation or adversarial fingerprint adoption make the score distribution unusable for a zero-false-positive threshold.

Attack-family, protocol and dataset coverage. The ontology and the evaluation cover the Slow HTTP DoS family over HTTP/1.1; HTTP/2 and other application protocols need sub-relations we have not modeled. Real-data validation spans six attacks across two datasets, all of them laboratory testbed captures, and the comparison with KLAGE is necessarily single-attack and differs in granularity and protocol, so reproducing KLAGE under our protocol is required before any superiority claim.

VII. Conclusion

We modeled the HTTP session as a first-class ontological entity and replaced flat cross-session relatedness with six typed sub-properties, weighted by the attacker's cost of breaking each signal. A SPARQL/SWRL rule fires on their weighted mass, so that one derivation serves at once as the verdict, the evidence chain and the scope of the mitigation.

Against stealthy distributed campaigns, per-session detection sits at chance across four classifier families given the full flow-feature set, while the framework's cross-session representation reaches 0.98 ROC AUC against 0.50 ($d = 22.4$, all 30 paired runs in the same direction); on conventional real attacks the gain is marginal, a strong per-session classifier already sufficing. The study also exposes a negative result: scoping by the property most of the cluster shares selects a legitimate fingerprint once the botnet spans several TLS stacks, blocking users instead of attackers, whereas enrichment over a profile of normal traffic restores 85–90% coverage with no observed collateral. Measured as a detector, that symbolic path recovers 90% of a 25-stack campaign where the learned model recovers 36% at the same zero-false-positive operating point, a gap the AUC hides. Immediate directions are HTTP/2 attacks and a captured stealthy campaign, which no benchmark yet provides.

ACKNOWLEDGMENT

We thank Azion Technologies for authorizing the aggregate fingerprint measurement of Section IV.

REFERENCES

[1] MITRE Corporation, "CVE-2023-44487: HTTP/2 rapid reset attack," National Vulnerability Database, 2023. [Online]. Available: https://nvd.nist.gov/vuln/detail/CVE-2023-44487

[2] Google Cloud, "How it works: The novel HTTP/2 'Rapid Reset' DDoS attack," Google Cloud Blog, 2023. [Online]. Available: https://cloud.google.com/blog/products/identity-security/how-it-works-the-novel-http2-rapid-reset-ddos-attack

[3] Cloudflare, "Hyper-volumetric DDoS attacks skyrocket: Cloudflare's 2025 Q2 DDoS threat report," Cloudflare Blog, 2025. [Online]. Available: https://blog.cloudflare.com/ddos-threat-report-for-2025-q2/

[4] E. Cambiaso, G. Papaleo, G. Chiola, and M. Aiello, "Slow DoS attacks: Definition and categorisation," *International Journal of Trust Management in Computing and Communications*, vol. 1, no. 3–4, pp. 300–319, 2013.

[5] C. Kemp, C. Calvert, T. M. Khoshgoftaar, and J. L. Leevy, "An approach to application-layer DoS detection," *Journal of Big Data*, vol. 10, no. 1, p. 22, 2023.

[6] M. Odusami, S. Misra, O. Abayomi-Alli, A. Abayomi-Alli, and L. Fernández-Sanz, "A survey and meta-analysis of application-layer distributed denial-of-service attack," *International Journal of Communication Systems*, vol. 33, no. 18, p. e4603, 2020.

[7] L. Belcastro, C. Carlucci, C. Cosentino, P. Liò, and F. Marozzo, "Enhancing network security using knowledge graphs and large language models for explainable threat detection," *Future Generation Computer Systems*, vol. 176, p. 108160, 2026.

[8] G. Fernandes Jr., J. J. P. C. Rodrigues, and M. L. Proença Jr., "Autonomous profile-based anomaly detection system using principal component analysis and flow analysis," *Applied Soft Computing*, vol. 34, pp. 513–525, 2015.

[9] R. Bharathi and R. Sukanesh, "A PCA based framework for detection of application layer DDoS attacks," *WSEAS Transactions on Information Science and Applications*, vol. 9, no. 12, pp. 389–398, 2012.

[10] L. Sadlek, M. Husák, and P. Čeleda, "Identification of device dependencies using link prediction," in *Proc. IEEE/IFIP Network Operations and Management Symp. (NOMS)*, 2024, pp. 1–10.

[11] X. Wang and R. Stadler, "IT intrusion detection using statistical learning and testbed measurements," in *Proc. IEEE/IFIP Network Operations and Management Symp. (NOMS)*, 2024, pp. 1–7.

[12] J. Althouse, J. Smart, R. J. Nunnally, and M. Brady, "JA4+ network fingerprinting," FoxIO, 2023. [Online]. Available: https://blog.foxio.io/ja4+-network-fingerprinting

[13] Y. Jia, Y. Qi, H. Shang, R. Jiang, and A. Li, "A practical approach to constructing a knowledge graph for cybersecurity," *Engineering*, vol. 4, no. 1, pp. 53–60, 2018.

[14] V. Bonagiri, P. Priyadharshini, P. PanneerSelvi, S. Sahitya, R. Swamy, and P. Varalakshmi, "Practical applications of cybersecurity: A research paper on knowledge graphs for real-world security solutions," in *Proc. 4th Asian Conf. on Innovation in Technology (ASIANCON)*, 2024.

[15] K. Liu, F. Wang, Z. Ding, S. Liang, Z. Yu, and Y. Zhou, "Recent progress of using knowledge graph for cybersecurity," *Electronics*, vol. 11, no. 15, p. 2287, 2022.

[16] N. Tripathi and N. Hubballi, "Application layer denial-of-service attacks and defense mechanisms: A survey," *ACM Computing Surveys*, vol. 54, no. 4, pp. 1–33, 2021.

[17] OASIS, "STIX version 2.1," OASIS Standard, 2021. [Online]. Available: https://docs.oasis-open.org/cti/stix/v2.1/stix-v2.1.html

[18] W3C OWL Working Group, "OWL 2 web ontology language profiles, 2nd ed." W3C Recommendation, 2012. [Online]. Available: https://www.w3.org/TR/owl2-profiles/

[19] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, "Toward generating a new intrusion detection dataset and intrusion traffic characterization," in *Proc. 4th Int. Conf. on Information Systems Security and Privacy (ICISSP)*, 2018, pp. 108–116.

[20] M. Antonakakis, T. April, M. Bailey, M. Bernhard, E. Bursztein, J. Cochran, Z. Durumeric, J. A. Halderman, L. Invernizzi, M. Kallitsis, D. Kumar, C. Lever, Z. Ma, J. Mason, D. Menscher, C. Seaman, N. Sullivan, K. Thomas, and Y. Zhou, "Understanding the Mirai botnet," in *Proc. 26th USENIX Security Symposium*, 2017, pp. 1093–1110.

[21] E. C. P. Neto, S. Dadkhah, R. Ferreira, A. Zohourian, R. Lu, and A. A. Ghorbani, "CICIoT2023: A real-time dataset and benchmark for large-scale attacks in IoT environment," *Sensors*, vol. 23, no. 13, p. 5941, 2023.

[22] E. Rescorla, K. Oku, N. Sullivan, and C. A. Wood, "TLS encrypted client hello," IETF Internet-Draft draft-ietf-tls-esni, 2024. [Online]. Available: https://datatracker.ietf.org/doc/draft-ietf-tls-esni/

[23] M. Shafi, A. H. Lashkari, V. Rodriguez, and R. Nevo, "Toward generating a new cloud-based distributed denial of service (DDoS) dataset and cloud intrusion traffic characterization," *Information*, vol. 15, no. 4, p. 195, 2024.

APPENDIX A
RUNTIME CONSTRUCTION AND SUB-RELATION INSTANTIATION

Algorithm 1 Runtime knowledge-graph construction

Require: request stream $\mathcal{R}$, ontology $\mathcal{O}$, window W
Ensure: knowledge graph KG persistent over W

$KG \leftarrow \emptyset$
for each request $r \in \mathcal{R}$ **do**
  $s, i, e \leftarrow$ RESOLVESESSION/IDENTITY/ENDPOINT(r)
  $KG.\mathrm{add}(s, i, e)$; $KG.\mathrm{link}(s, \texttt{hasIdentity}, i)$
  $KG.\mathrm{link}(s, \texttt{targets}, e)$
  for each active $s' \in S_W$, $s' \neq s$ **do**
    for each sub-relation $i \in \mathcal{R}_{\mathrm{rel}}$ **do**
      if $\textsc{Holds}_i(s, s')$ **then**
        $KG.\mathrm{link}(s, \texttt{relatedBy}_i, s')$
      end if
    end for
  end for
  $KG.\mathrm{purgeOutside}(W)$
end for
return KG

Algorithm 1 constructs the graph over the sliding window. For each pair (s_a, s_b) active in W, the following procedures decide whether the edge is instantiated.

`TLSFingerprint`. Two-stage match: exact equality of the full JA4 or, failing that, near variants (same transport/TLS-version/ALPN prefix, at most one symbol of difference in the ordered cipher or extension blocks), instantiated with a *ja4_distance = 1* annotation. This absorbs version drift within one client library without admitting spurious matches across distinct stacks. Cost $O(1)$ per pair.

`ReusedIdentity`. Instantiated on any non-empty overlap between the observed identity sets, $(\mathrm{cookie}(s_a) \cap \mathrm{cookie}(s_b)) \cup (\mathrm{token}(s_a) \cap \mathrm{token}(s_b)) \cup (\mathrm{user}(s_a) \cap \mathrm{user}(s_b)) \neq \emptyset$. JWTs are decoded and compared by the `sub` claim; cookies and usernames are normalized (trim, lower-case). Cost $O(1)$ amortized with an inverted index.

`TemporalPattern`. With $\Delta(s)$ the sequence of inter-arrival times, we compute $d_{\mathrm{DTW}}(s_a, s_b) = \mathrm{DTW}(\Delta(s_a), \Delta(s_b)) / \max(|\Delta(s_a)|, |\Delta(s_b)|)$ and instantiate when $d_{\mathrm{DTW}} \leq \tau_{\mathrm{DTW}}$. Sessions with fewer than three requests are skipped. FastDTW under a constant-width Sakoe–Chiba band reduces the per-pair cost from $O(n^2)$ to $O(n)$, and locality-sensitive hashing over summary vectors ($\bar{\delta}$, σ_δ, $\delta_{\min}$, $\delta_{\max}$, entropy) avoids all-pairs comparison.

```
# SWRL (Horn): instantiate one sub-relation
ApplicationSession(?a) ^ ApplicationSession(?b) ^
  differentFrom(?a,?b) ^
  tlsJa4(?a,?j) ^ tlsJa4(?b,?j)
  -> relatedByTLSFingerprint(?a,?b)

# SPARQL: weighted aggregation over the cluster
SELECT ?e (SUM(?w) AS ?omega) (COUNT(*) AS ?pairs)
WHERE { ?a kg:targets ?e . ?b kg:targets ?e .
        ?a ?rel ?b .
        ?rel rdfs:subPropertyOf kg:relatedTo ;
             kg:coordinationWeight ?w .
        FILTER(STR(?a) < STR(?b)) }
GROUP BY ?e HAVING (SUM(?w) >= ?tau)
```

Listing 1. Verdict as derivation: one Horn rule and the SPARQL aggregation.

`PayloadSignature`. With $\mathbf{p}(s) = (\overline{\text{len}}, \sigma_{\text{len}}, h_{\text{UA}}, h_{\text{CT}})$ — mean and standard deviation of body size, plus hashes of the dominant User-Agent and Content-Type — the edge is instantiated when cosine similarity exceeds τ_{payload}. Cost $O(1)$ given precomputed vectors.

`EndpointConvergence`. Instantiated when both sessions converge on the same endpoint, under path-pattern normalization (`/api/users/12345` $\rightarrow$ `/api/users/{id}`) by default; an additional exact-path match annotates the edge with *exact* = *true*. Cost $O(1)$ with a prefix-tree index.

`NetworkProximity`. Instantiated on a shared IPv4 /24 (or IPv6 /48) prefix, or a shared ASN, or both; when both hold the edge is annotated *strong* = *true*. ASN resolution uses current BGP tables. Cost $O(1)$ with an inverted prefix index.

Appendix B
Weight Calibration

Empirical calibration depends critically on the realism of the traffic. On laboratory datasets, with a few dozen distinct JA4 fingerprints, optimization even inverts the sign of the TLS signal, because benign sessions share fingerprints more than partially coordinated campaigns do; this is a testbed artifact of low JA4 diversity, absent from the real internet.

In the realistic scenario (thousands of legitimate JA4 fingerprints, users hitting the attacked service), we calibrate by maximizing per-session attack-vs-benign ROC AUC over the score $w_{\text{tls}}\, z(\text{ja4}) + w_{\text{ep}}\, z(\text{endpoint conv.}) + w_{\text{net}}\, z(\text{net prox.})$ with standardized attributes, over the grid $\{0.3 \ldots 1.0\}^3$ (125 combinations, 60 scenarios, 91 500 sessions). The result corroborates the proposed ordering: the best vector is (w_{tls}=1.0, w_{ep}=0.3, w_{net}=0.3), and the TLS fingerprint is the only individually discriminative signal (isolated AUC = 0.93, against 0.50 for endpoint convergence and 0.58 for network proximity). The weights of Fig. 1 (1.0, 0.6, 0.3) attain the same optimal AUC = 0.943 and are insensitive to $\pm 20\%$ perturbation (no measurable drop). Calibration therefore validates the *ordering*; in the pure same-service regime the medium and low weights are not separately identifiable, since in isolation both sit near chance, and their absolute values remain open pending production traffic with partial and conflicting signals.

Generator Realism

Two caveats apply to the production measurement of benign fingerprint popularity. The log carries no connection identifier, so weighting is per request, not per session, which overweights heavy clients and if anything *overstates* concentration; and the sample is one point of presence over one window. The CICIDS2017 testbed [19] is more concentrated still (52.7% head), so laboratory shape is indicative only. The measured curve is also not exactly Zipf: its head matches $\alpha = 1.5$ (38.9% against 38.4%) while its top ten matches $\alpha = 2.0$ (94.2% against 93.8%), so the sweep brackets it.

Appendix C
Additional Limitations

Session and identity instrumentation. The approach assumes sessions, identities and TLS fingerprints can be extracted from traffic events; where that instrumentation is partial or noisy, performance degrades.

Graph maintenance cost. The symbolic figures of Appendix D are an upper bound, for the reason given there; and scaling to CDN-scale traffic requires the horizontal partitioning of Section VI, which we did not implement.

Protocol coverage. The current ontology covers the Slow HTTP DoS family over HTTP/1.1. HTTP/2 attacks and other application protocols (DNS, gRPC) need additional sub-relations.

Sub-relation coverage. The evaluated $\Omega(S)$ instantiates three of the six sub-relations — TLS fingerprint, endpoint convergence, network proximity — the ones the generator and the public captures expose. Identity reuse, temporal pattern and payload signature are specified in Appendix A but not exercised, so the weights of Fig. 1 are validated only for those three.

Dataset breadth. Real-data validation covers one dataset and one attack for the head-to-head comparison, plus six attacks across CICIDS2017 and CIC-IoT2023 for the regime analysis. RT-IoT2022, CIC-DDoS2019 and anonymized production traffic remain future work. The gap persists in newer benchmarks: BCCC-cPacket-Cloud-DDoS-2024 [23] identifies inadequate application-layer attack representation as a dataset deficiency, yet its 17 DDoS scenarios are all TCP-based. Among the benchmarks examined we therefore found no independent capture of the stealthy Layer-7 regime studied here.

Explanation validation. Evidence chains pass the automated completeness and actionability checks of Section IV (7/7). We ran no user study, so whether they shorten an analyst's time to decision is untested.

Appendix D
Cost Model and Window Sensitivity

Admission happens per request while symbolic materialization and the Ω aggregation run once per window, so we time them separately, on a synthetic window in the realistic same-service mix (30% of sessions in one campaign sharing a botnet JA4, benign JA4 from a pool of 2 000, eight endpoints,

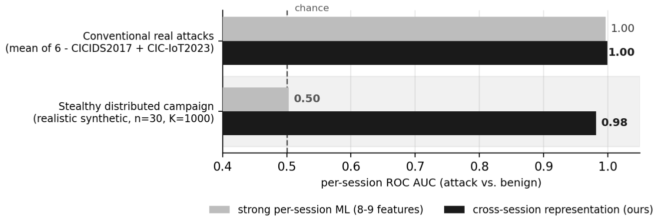

Fig. 4. Where cross-session evidence is needed.

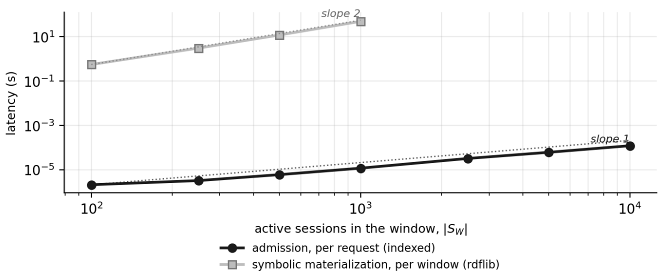

Fig. 5. Cost of the two layers against window occupancy.

TABLE V
WINDOW SWEEP, $K = 1000$, $n = 10$ SEEDS.

W (s)	clusters	mean $\|S\|$	(a)	(b)	(c)	(d)
60	16	132	0.505	0.508	0.664	0.976
120	11	207	0.505	0.508	0.663	0.977
300	6	364	0.505	0.508	0.664	0.977
600	4	557	0.505	0.508	0.664	0.978
1800	3	867	0.505	0.508	0.664	0.978

dispersed /24s), reporting medians over three repeats on one core. This is a cost model of the algorithm as specified, not a system benchmark: the symbolic layer runs on in-memory `rdflib`, not the Jena/TDB2 backend, so its figures are an upper bound.

Admission behaves as the bound predicts (Fig. 5, where the dotted lines are reference slopes anchored on the first point of each series): median latency grows from $2.1\,\mu$s at $|S_W| = 100$ to $122\,\mu$s at $|S_W| = 10\,000$, tracking the candidate-pair count (148 to 6 495 edges per admission) at a constant 14–20 ns per pair.

The symbolic layer is orders of magnitude more expensive: 0.56 s at $|S_W| = 100$ rising to 49.7 s at $|S_W| = 1\,000$. Read per unit of work, however, cost stays within 180–$210\,\mu$s per materialized RDF edge across all sizes, so the layer is *linear in edges*; it is the edge count that grows quadratically, because $\Omega(S)$ is defined over pairs. The quadratic term is thus a property of the rule rather than of the backend, and it points at the deployment split the architecture implies: detect on the indexed admission path, and materialize RDF only for the clusters that fire.

W enters only through detection-cluster assignment, so the sweep recomputes the cross-session features on the same cached scenarios. Table V shows detection is insensitive to it over 60–1800 s: the discriminative feature is the *fraction*

```
"@type": "kg:CoordinatedHTTPFlood",
"kg:clusterSize": 6, "kg:coordinationScore": 10.8,
"kg:activatedSubRelations": [
 {"@type": "kg:relatedByEndpointConvergence",
  "kg:coordinationWeight": 0.6, "kg:linkedPairs": 15,
  "kg:weightedContribution": 9.0},
 {"@type": "kg:relatedByNetworkProximity",
  "kg:coordinationWeight": 0.3, "kg:linkedPairs": 6,
  "kg:weightedContribution": 1.8}],
"kg:derivedMitigationScope": {
  "kg:endpoint": "192.168.10.50:80",
  "kg:srcNet24":  "172.16.0.0/24"}
```

Listing 2. Evidence chain for the CICIDS2017 DoS-Other cluster (JSON-LD, abridged).

of a cluster sharing one JA4, which does not change as the cluster grows, whereas cluster size alone carries little; hence (c) at 0.664 throughout. Two bounds: the scenarios target a single endpoint, so W is the only clustering knob and a multi-endpoint deployment may behave differently; and W must be long enough for a cluster to form, which at $W = 60$ s already means ≈ 132 sessions.

Partitioning at CDN Scale

The design that endpoint sharding suggests, unimplemented here, is two-tiered: endpoint-sharded workers plus a global sketch over high-weight identifiers to recover campaigns that spread across endpoints. Quantifying the recall lost by the first tier and recovered by the second is a precondition for CDN-scale deployment. With the cost model above, the scalability argument is that endpoint sharding is exact and needs no coordination, a small W cuts the quadratic pair term at no cost in detection, and admission is microseconds; confirming that at CDN scale remains future work.

APPENDIX E
REPRODUCIBILITY

The reference implementation is available at https://github.com/Natanael0liveira/knowledge-graph-ddos-article under a permissive license. It is organized by experimental stage: the extraction pipeline (PCAP $\rightarrow$ JA4 and flows $\rightarrow$ sessions $\rightarrow$ graph); the calibrated generator, with the realism parameters of Section IV and its canonical and adversarial configurations; the ablation, the academic baselines, the four classifier families and the statistical runner; the symbolic layer, SWRL rules plus the SPARQL aggregation with weights read from the ontology; and the evidence and mitigation modules.

Both scope derivations ship side by side: the frequency rule that fails and the enrichment rule that replaces it, so the negative result of Section V-D is reproducible rather than asserted. The background profile the enrichment test needs is produced by an attack-free generator run, so no labels enter the decision path at any point.

Seeds are fixed, orchestration is driven by Makefiles, and artifacts are versioned, so every table and data figure regenerates from a single command per stage. Fig. 1 is a schematic; its source ships with the artifact. The OWL ontology is provided in RDF/XML, with every `relatedBy` sub-property annotated with its `coordinationWeight`. We intend to submit these artifacts to the Artifact Evaluation track.